

Clase 223 — Seguridad en AWS

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *AWS Well-Architected Framework: Security Pillar y CIS Amazon Web Services Foundations Benchmark* 🕒 Duración estimada: **130 min** · Nivel: **Intermedio**

Objetivo

Endurecer una cuenta de AWS aplicando los controles nativos clave: segmentación de red con VPC y security groups, protección de datos con cifrado y KMS, aislamiento de almacenamiento S3, y los servicios de seguridad gestionados (GuardDuty, Security Hub, Config). Al terminar, el alumno podrá llevar una cuenta desde su estado por defecto hasta una postura alineada con el CIS Benchmark.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diseñar** una VPC segura con subredes públicas/privadas, security groups y NACLs.
2. **Bloquear** el acceso público a S3 y aplicar cifrado en reposo con KMS.
3. **Habilitar** GuardDuty, Security Hub y Config para detección y postura continua.
4. **Configurar** VPC Flow Logs y CloudTrail multi-región para trazabilidad.
5. **Interpretar** los hallazgos del CIS AWS Benchmark en una cuenta real.

Temas

#	Tema	Por qué importa
1	VPC, subredes y security groups	Segmentación de red y control de tráfico
2	S3: block public access y políticas	Buckets públicos son la fuga clásica
3	Cifrado en reposo y KMS	Protege datos y controla claves
4	GuardDuty	Detección de amenazas basada en logs
5	Security Hub	Consolidación de hallazgos y benchmarks
6	AWS Config	Inventario y evaluación de cumplimiento continuo
7	CloudTrail y Flow Logs	Auditoría de API y tráfico de red

Definiciones y características

- **VPC:** red virtual aislada dentro de AWS. *Clave:* subredes privadas sin ruta a Internet reducen exposición.
- **Security Group:** firewall stateful a nivel de instancia. *Clave:* solo permite (allow); denegar es no incluir la regla.

- **NACL:** firewall stateless a nivel de subred. *Clave:* permite reglas deny explícitas, complementa a los SG.
- **S3 Block Public Access:** interruptor de cuenta/bucket que anula ACLs y políticas públicas. *Clave:* actívalo a nivel de cuenta.
- **KMS:** servicio de gestión de claves. *Clave:* separa quién administra la clave de quién la usa; auditable vía CloudTrail.
- **GuardDuty:** detección de amenazas que analiza CloudTrail, DNS y Flow Logs. *Clave:* sin agentes, se activa con un clic.
- **Security Hub:** agrega hallazgos y ejecuta el CIS/AWS FSBP benchmark. *Clave:* panel único de postura.

Herramientas y preparación

- CLI `aws` configurada con un perfil de laboratorio y MFA.
- **Prowler** para el CIS AWS Benchmark: `pip install prowler`.
- Cuenta de laboratorio dedicada; no uses la cuenta de producción.

```
# Comprobar que S3 no permite acceso público a nivel de cuenta
aws s3control get-public-access-block --account-id 123456789012
# Habilitar GuardDuty en la región actual
aws guardduty create-detector --enable
```

Laboratorio guiado

1. Crea una VPC con una subred pública (con Internet Gateway) y una privada (sin ruta directa a Internet).
2. Lanza una instancia en la subred privada y comprueba que no es accesible desde Internet; da acceso solo vía un bastión o SSM Session Manager.
3. Crea un bucket S3, sube un objeto y verifica que **Block Public Access** está activo a nivel de cuenta y bucket. Intenta hacerlo público y confirma que se bloquea.
4. Activa cifrado por defecto con una clave KMS gestionada por ti y revisa la política de la clave.
5. Habilita **CloudTrail** multi-región con un bucket dedicado y cifrado, y **VPC Flow Logs** hacia CloudWatch.
6. Activa **GuardDuty, Config** (con reglas gestionadas) y **Security Hub** con el estándar CIS.
7. Ejecuta `prowler aws --compliance cis_2.0_aws` y compara los hallazgos con lo que muestra Security Hub. Corrige al menos tres hallazgos de severidad alta y vuelve a ejecutar.

Ejercicios

1. Escribe una regla de security group que permita SSH solo desde tu IP y HTTPS desde cualquier origen.
2. Crea una política de bucket que exija cifrado en las peticiones `PutObject`.
3. Configura una regla de Config que marque como no conforme cualquier volumen EBS sin cifrar.
4. Interpreta un hallazgo de GuardDuty de tipo `UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration`.
5. Diseña una arquitectura de cuentas con una cuenta de logging centralizado.
6. Habilita el acceso a instancias vía SSM en lugar de SSH y explica la ventaja de seguridad.

Reto verificable

Toma una cuenta de laboratorio "recién creada" y llévala a una postura base: sin buckets públicos, CloudTrail multi-región activo, GuardDuty y Security Hub habilitados, y cifrado por defecto en S3 y EBS.

Criterio de aceptación: una ejecución de `prowler aws --compliance cis_2.0_aws` muestra 0 hallazgos críticos/altos en las secciones de S3, logging y cifrado, y Security Hub reporta esos controles como `PASSED`.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Bucket "public" pese a política privada	ACL heredada o BPA desactivado; activa Block Public Access a nivel de cuenta.
SG "no funciona" al denegar un puerto	Los SG solo permiten; para deny explícito usa NACL a nivel de subred.
GuardDuty sin hallazgos aunque hay actividad	Solo cubre la región activada; habilítalo en todas las regiones usadas.
CloudTrail sin registros históricos	Solo captura desde su creación; créalo antes de necesitarlo, multi-región.
<code>AccessDenied</code> al usar una clave KMS	Falta permiso en la política de la clave; añade el principal a <code>kms:Decrypt</code> .

Preguntas frecuentes

? ¿Security Group o NACL? Usa ambos. El SG es stateful y va en la instancia (control fino); el NACL es stateless, va en la subred y sirve para bloqueos amplios (deny) que el SG no puede expresar.

? ¿GuardDuty reemplaza a un SIEM? No. GuardDuty detecta amenazas conocidas a partir de los logs de AWS; un SIEM correlaciona múltiples fuentes. Lo habitual es enviar los hallazgos de GuardDuty al SIEM.

? ¿Debo usar claves gestionadas por AWS o por el cliente (CMK)? Para control de auditoría, rotación y separación de deberes, usa claves gestionadas por el cliente (CMK). Las gestionadas por AWS son cómodas pero dan menos control sobre la política.

Referencias

- AWS Well-Architected — Security Pillar. <https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>
- CIS Amazon Web Services Foundations Benchmark. https://www.cisecurity.org/benchmark/amazon_web_services
- Amazon S3 — Blocking public access. <https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html>
- Amazon GuardDuty docs. <https://docs.aws.amazon.com/guardduty/>
- Prowler. <https://github.com/prowler-cloud/prowler>

Siguiente clase

Clase 224 - Seguridad en Azure